

ISO/IEC 27001:2022 – Annex A Control 5.26

Information Security Incident Response Report

Organization: ApexNova Technologies

Related Documents: ISO-IMP-2026-001 (Incident Management Policy); ISO A.5.25 Incident Assessment & Decision Report

Classification: Internal

1. Incident Overview

This report documents the operational response to a confirmed information security incident, classified as Medium Severity (P3) under ISO/IEC 27001:2022 Annex A Control 5.25. The response was executed in accordance with documented incident response procedures, fulfilling the requirements of Annex A Control 5.26.

Incident ID: INC-2026-03-003

Date/Time Confirmed: March 3, 2026 – 10:42 UTC

Incident Type: Unauthorized Access Attempt (Credential Stuffing)

2. Incident Response Activation

Following the formal decision recorded under Annex A Control 5.25, the Incident Response Team (IRT) was activated within 30 minutes. Team members possessed the authority to implement containment actions, including network controls and account restrictions.

3. Containment Actions

Timestamp	Action	Responsible Role
11:05 UTC	Blocked malicious IP ranges at firewall	Incident Responder
11:12 UTC	Enabled rate-limiting controls on authentication endpoints	SOC Manager
11:20 UTC	Monitored targeted accounts for anomalous activity	SOC Analyst

4. Eradication Actions

No malware or system compromise was identified. Eradication focused on eliminating the root cause by strengthening authentication controls and removing the attack vector.

- Password resets enforced on potentially targeted accounts
- Authentication monitoring rules enhanced
- SIEM correlation logic updated to detect future credential stuffing attempts

5. Recovery Actions

Because system availability was not disrupted, recovery actions focused on validation rather than restoration. All services remained operational throughout the incident lifecycle.

- Verified integrity of authentication services
- Confirmed no unauthorized access to production data
- Continued heightened monitoring for 72 hours post-incident

6. Communication and Regulatory Considerations

An assessment confirmed that no personal data breach occurred. Therefore, regulatory notification under GDPR Article 33 (72-hour rule) was not required. Internal communication followed Section 7 of the Incident Management Policy, with notification provided to the CISO.

7. Evidence Collection and Preservation

Evidence was collected and preserved to support auditability and potential legal review:

- SIEM logs related to authentication attempts
- Firewall and WAF logs
- Incident ticket records from ITSM platform

8. Formal Closure

The incident was formally closed on March 6, 2026, following completion of response actions, verification of system integrity, and documentation of lessons learned. This closure satisfies the formal completion requirements of Annex A Control 5.26.

Approved By: Alexandra Pierce, Chief Information Security Officer

Date: March 6, 2026